

TLS 연결의 양자 위협 기반 계층적 위험도 산출 모델

형유림*, 정수민*, 임다은*, 박도윤*, 조수빈*, 김재환*, 서화정†
한성대학교 (학부생, 교수†)

연구 배경 및 문제 정의

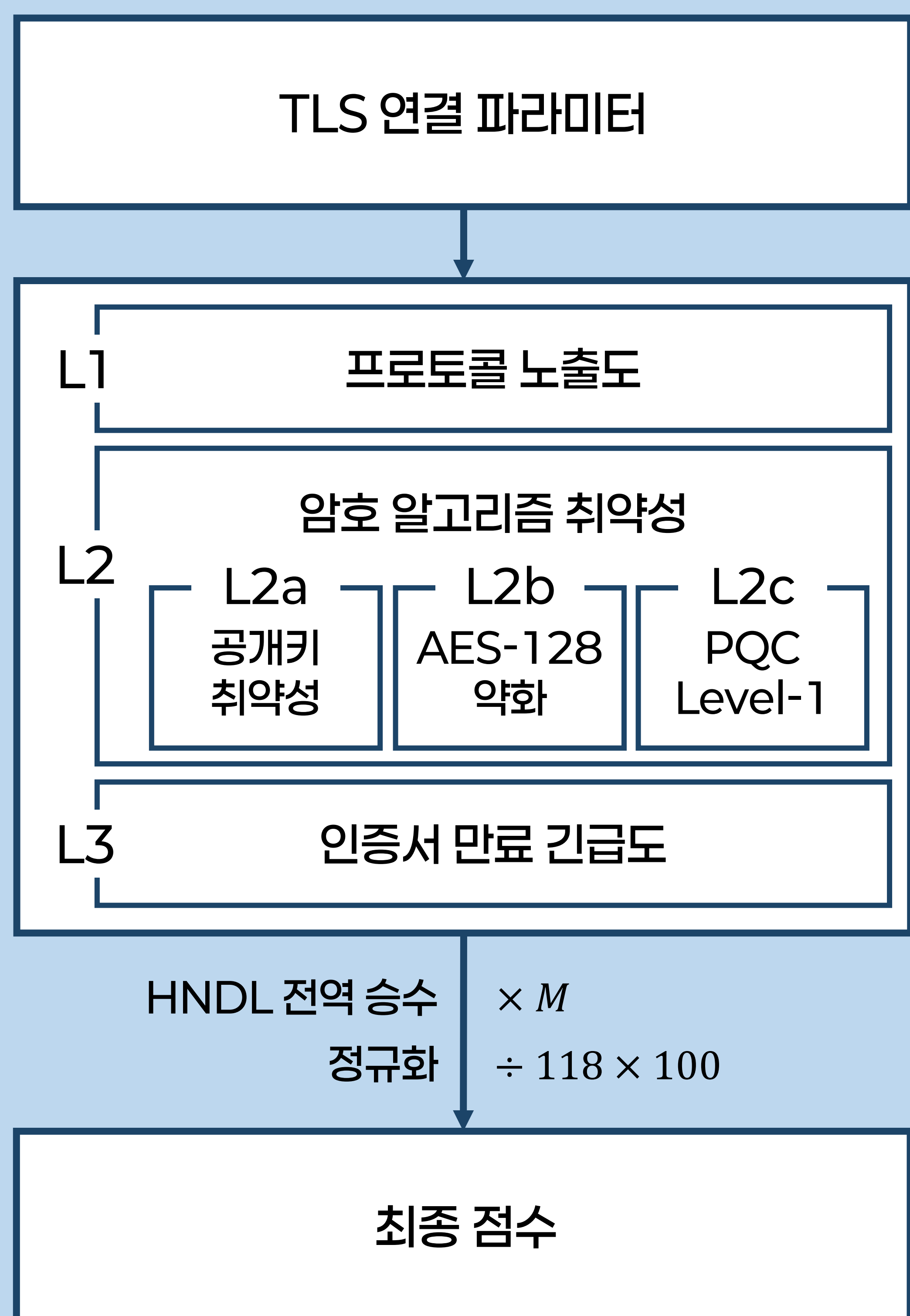
연구 배경 및 문제 정의

양자 컴퓨터의 발전으로 TLS에서 사용하는 RSA·ECDHE 등 공개키 암호가 Shor 알고리즘에 의해 무력화될 위험에 처하고 있으며, Harvest Now, Decrypt Later(HNDL) 공격은 양자 컴퓨터 실용화 이전에도 장기 기밀성이 요구되는 TLS 연결을 위협에 노출시킨다. 또한 Grover 알고리즘은 AES-128의 실효 보안 강도를 64비트로 절반 감소시킨다. NIST가 2024년 ML-KEM 등 PQC 최종 표준을 확정하였음에도 불구하고, 실환경에서는 레거시 연결이 광범위하게 잔존하고 있다. 그러나 기존 프레임워크(CVSS v3.1, Baseri 등)는 TLS 연결 파라미터를 직접 입력으로 받아 HNDL 위협을 정량화하지 못하며, 개별 TLS 연결의 양자 취약성을 즉각 정량화하는 방법론이 부재한다.

제안 모델

제안 모델

본 모델은 그림 1과 같이 TLS 연결 하나를 평가 단위로 하며, 5개 독립 레이어의 점수를 합산한 후 HNDL 전역 승수 M을 곱하고 정규화하여 0~100점 범위로 출력한다. 최종점수는 $(L1 + L2a + L2b + L2c + L3) \times M / 118 \times 100$ 의 내림값으로 산출된다. 각 레이어는 독립적으로 산출되어 위험 원인의 분해(decomposition)를 가능하게 하며, 운영자가 레이어별 점수를 기반으로 대응 우선순위를 결정할 수 있도록 지원한다.



<그림 1> 전체 파이프라인 구조

레이어별 구성

L1

L1은 TLS 버전과 키 교환 방식을 반영한 프로토콜 노출도로, TLS 1.3 표준 연결의 경우 0점이 산출된다.

L2

L2는 암호 알고리즘 취약성을 평가하는 세 개의 서브레이어로 구성된다. L2a는 Shor 알고리즘에 취약한 RSA·ECDHE 사용 시 발동하며, 노출 범위 e(로컬/내부망/인터넷)에 따라 보정된다. L2b는 AES-128 사용 연결에 Grover 약화를 반영한 고정값을 적용하며, AES-256 연결에는 발동하지 않는다. L2c는 하이브리드 PQC 사용 중 NIST Level-1 알고리즘이 적용된 경우에 발동한다.

L3

L3는 인증서 만료까지 남은 일수 d에 따라 산출하며, 만료 30일 이내에서 선형 증가하고 만료 시 최대값을 가진다.

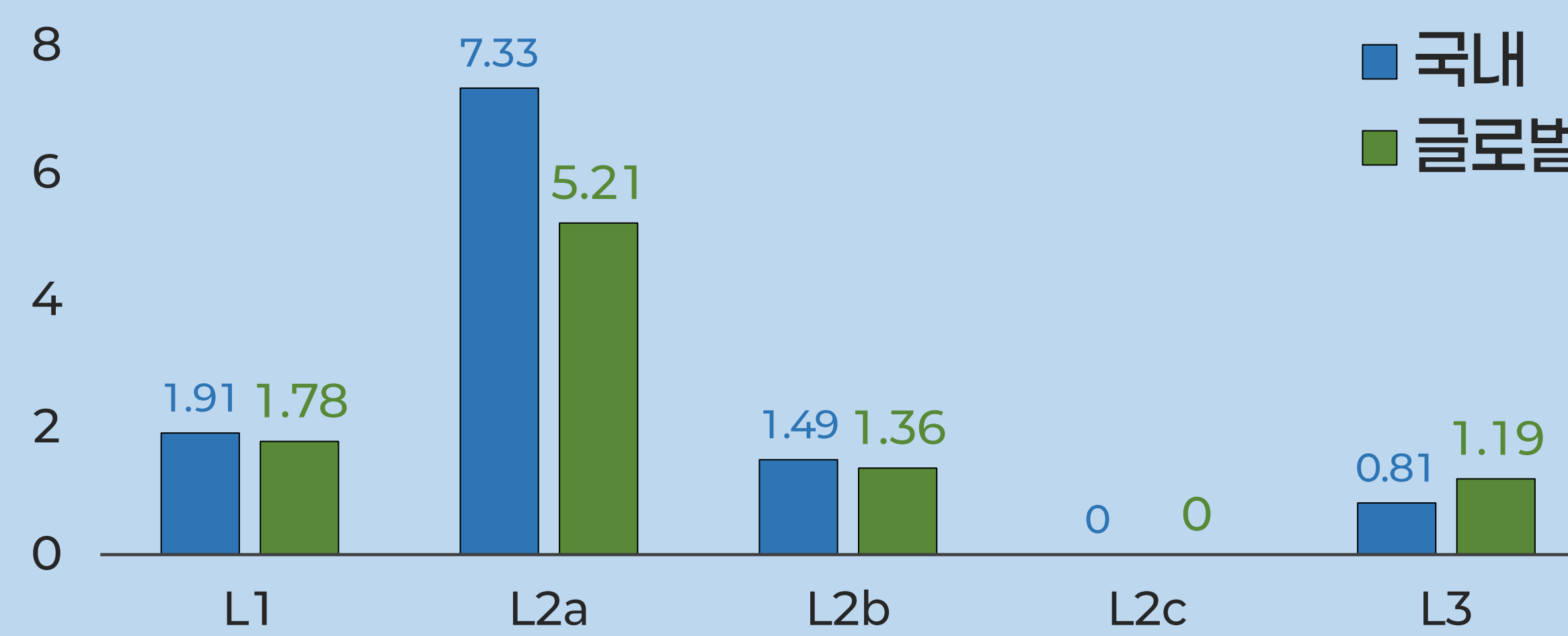
HNDL 보정

HNDL 전역 승수 M은 기밀 유지 기간 h년을 반영하여 $M = 1 + h/20$ 으로 산출되며, 범위는 [1.0, 2.0]이다.

실험 및 결과

실험 및 결과

국내외 주요 기업 20개사에서 총 123개 TLS 세션(국내 70, 글로벌 53)을 수집하고 $h = 10$ ($M = 1.50$)을 적용하여 검증하였다. 그 결과 국내 평균 17.74점, 글로벌 평균 14.64점으로 3.1점의 격차가 확인되었으며, L2a가 점수 격차의 주요 원인으로 나타났다. 이는 국내 RSA·ECDHE 잔존율(64.3%)이 글로벌(49.1%)보다 높기 때문이다.



<그림 2> 레이어별 국내·글로벌 평균 점수 비교

결론

결론

본 논문은 TLS 연결의 양자 취약성을 0~100점으로 정량화하는 최초의 연결 단위 계층적 위험도 산출 모델을 제안하고 실환경에서 검증하였다. 5개 독립 레이어를 통한 위험 원인의 분해와 HNDL 전역 승수 M을 통해 시간적 위험 차원을 동시에 정량화하며, 실험을 통해 국내 PQC 전환의 시급성을 정량적으로 입증하였다. 향후에는 환경 보정 승수 m의 자동 추정 및 QUIC 확장을 수행하고, 본 모델을 조직 전반의 양자 전환 프레임워크로 발전시키고자 한다.